Informática Forense y Respuesta ante Incidentes

Tema 1. Introducción a la Respuesta a Incidentes y Análisis Forense

Índice

Esquema

Ideas clave

1.1. Introducción y objetivos

1.2. Introducción a la respuesta a incidentes

1.3. Introducción al Análisis Forense Digital

1.4. Aspectos legales relacionados

1.5. Referencias bibliográficas

A fondo

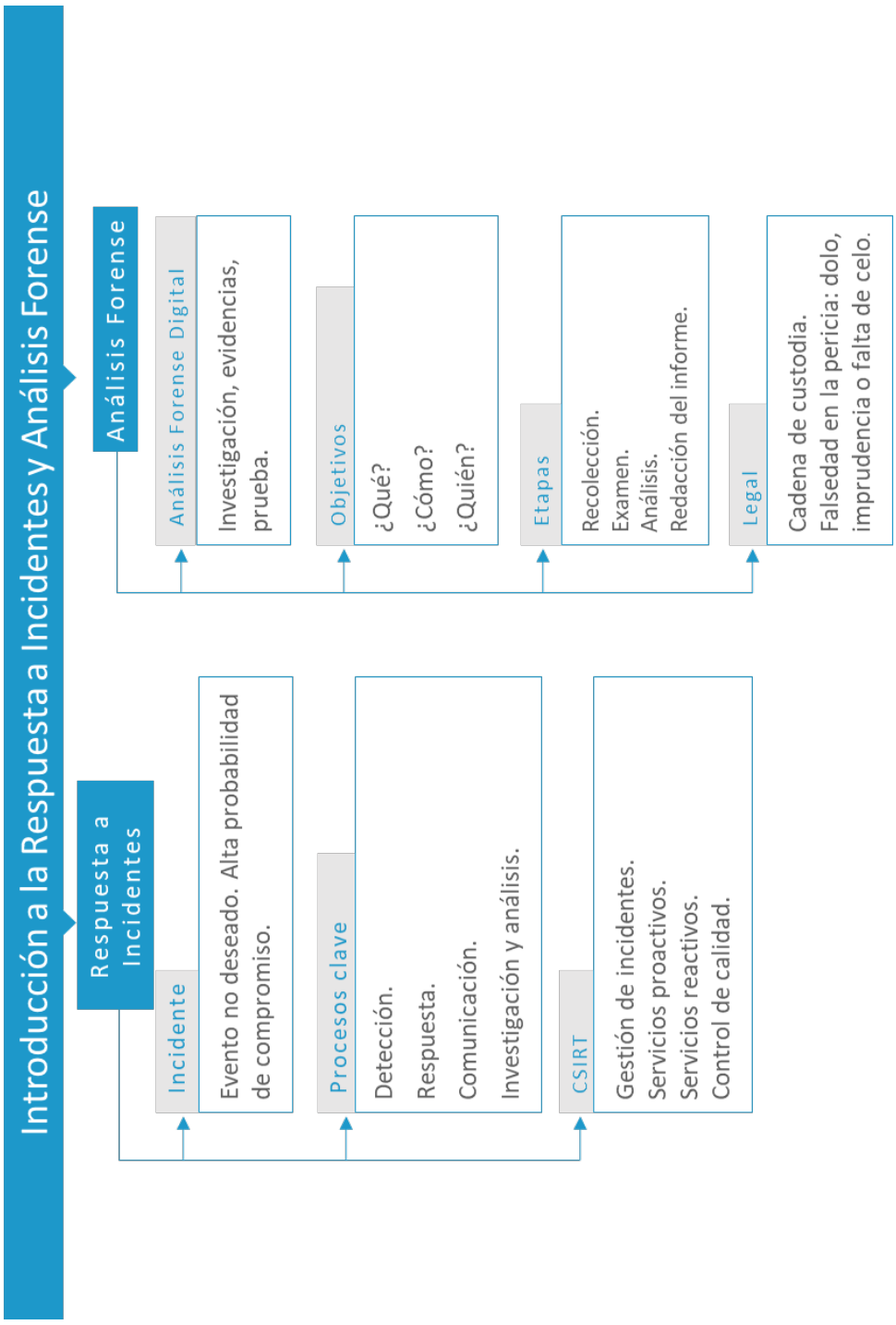
Who is Who During a Cyber Incident Response Investigation

Respuesta a Incidentes: Políticas de seguridad para la PYME

Digital Forensics, Davin Teo

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

1.1. Introducción y objetivos

Este tema de la asignatura pretende introducirnos en el mundo de la Respuesta a Incidentes y el Análisis Forense Digital. Se busca adquirir unos conocimientos mínimos sobre los que, posteriormente, se asentará el resto de la asignatura.

Los objetivos son:

- Conocer la importancia de la gestión de incidentes, su contexto dentro del negocio, procedimientos y métricas.
- Conocer la infraestructura de gestión de incidentes y alerta temprana.
- Entender la necesidad de recabar información de manera simultánea a la recuperación en el proceso de gestión de incidentes.
- Conocer qué es el análisis forense digital y cuáles son sus objetivos.
- Saber identificar cada una de las etapas de un análisis forense.
- Comprender los aspectos legales relacionados con nuestras actuaciones.

© Universidad Internacional de La Rioja (UNIR)

1.2. Introducción a la respuesta a incidentes

¿Qué es un incidente?

Un incidente de seguridad es **un evento no deseado** con alta probabilidad de comprometer las operaciones de la entidad y amenazar una o varias de las tres dimensiones de la seguridad de la información: confidencialidad, disponibilidad e integridad. Este evento puede desencadenarse de **manera espontánea o provocada.** En este segundo caso hablamos de **ciberataque.**

Según el NIST (NIST, 2013), el ciberataque es un ataque, a través del ciberespacio, dirigido al uso del ciberespacio por parte de una empresa con el fin de interrumpir, inutilizar destruir o controlar maliciosamente un entorno o una infraestructura informática; o destruir la integridad de los datos o el robo de información controlada.

Existen modelos como el ATT&CK del MITRE que intentan caracterizar cualquier tipo de ciberataque con el objetivo de sistematizar el proceso de reacción ante dichos ataques. Se puede acceder a la página web a través del siguiente link: http://attack.mitre.org.

Respuesta a incidentes

La respuesta a incidentes engloba al conjunto de procedimientos necesarios para afrontar un incidente de manera óptima tanto a nivel tecnológico como de negocio. De este modo, existen diferentes aproximaciones diferentes para dicha respuesta.

Perspectiva de negocio: Business Continuity

La Continuidad de Negocio (o BC – Business Continuity) trata de la

© Universidad Internacional de La Rioja (UNIR)

continuidad de los procesos productivos de la compañía ante cualquier tipo de eventualidad (no solo tecnológica).

Los **incidentes** pueden ser de diversa naturaleza. Algunos de los más comunes son:

- **Desastres naturales:** son imposibles de evitar y de predecir, y pueden provocar un alto impacto, por lo que se ha de elaborar un plan de contingencias detallado ante este tipo de acontecimientos.
- **Ataques:** provienen de fuentes externas y pueden tener diferentes motivaciones, por lo que el ataque puede perseguir diferentes finalidades y, por tanto, su tipología puede ser muy diferente.
- **Ataque interno:** son los ataques de los llamados *insiders.* Son muy difíciles de detectar de manera temprana y, normalmente, cuando se detectan ya el daño causado es amplio. Por ello, son importantes las políticas de control de acceso que regulen y acoten el radio de acción.
- **Errores humanos:** son inherentes a la actividad, y pueden ser causados por la llamada ingeniería social. El mejor modo de prevenirlos es mediante políticas de formación corporativa.

La gestión de la continuidad de negocio o Business Continuity Management (BCM) trata de sistematizar la respuesta mediante:

- Definición de los procesos críticos del negocio y su nivel de criticidad como primer paso para identificar los puntos más críticos de la organización.
- Una vez identificados dichos procesos, se emplea una metodología de evaluación de riesgos y una estrategia de elaboración de contingencias ante los riesgos encontrados. La tipología de riesgos habitual permite distinguir:

© Universidad Internacional de La Rioja (UNIR)



Figura 1. Gestión de la continuidad de negocio. Fuente: elaboración propia.

- Dicha estrategia no solo tendrá en cuenta la recuperación de los procesos a su estado inicial, sino que se evaluará en el intervalo de recuperación:
  - ¿Cómo se van a gestionar las interrupciones?
  - ¿Existe algún mecanismo de operación alternativa?
  - ¿Cuáles son los niveles mínimos de servicio aceptables?
  - ¿Cómo minimizar el impacto económico que está sufriendo?
- Por último, el personal deberá ser entrenado para poder activar los mecanismos de

© Universidad Internacional de La Rioja (UNIR)

contingencia cuando sea necesario.

Perspectiva tecnológica: Disaster Recovery

Recuperación ante desastres o Disaster Recovery supone el restablecimiento de la infraestructura tecnológica ante un desastre de origen natural o humano (por ejemplo, un ciberataque).

Según el INCIBE, un plan de recuperación ante desastres ha de tener en cuenta las siguientes **fases:**

- Alinearlo con el **plan de continuidad** de negocio.
- Realizar una **evaluación de riesgos** para conocer las actividades críticas.
- Llevar a cabo un **análisis de impacto de negocio** (BIA). Identificar las necesidades de la organización en términos de recuperación.
- Desarrollar las **medidas de recuperación** para los servicios y las aplicaciones prioritarias, de manera que se puedan poner en práctica los mecanismos para volver a la operación normal lo antes posible.
- Realizar **pruebas periódicas.** Debemos asegurar el correcto funcionamiento de nuestro plan de recuperación y probar que las medidas que hemos considerado necesarias realmente son las adecuadas para recuperar nuestros sistemas.
- **Actualizar y mejorar el plan** con la información obtenida. Además de un mecanismo de mejora de la calidad, las amenazas evolucionan constantemente, por lo que debemos asegurarnos de que nuestro plan no se queda desactualizado.
- **Capacitar a los encargados** de ponerlo en marcha, concienciar y difundir el plan.

Como vemos, el plan de recuperación ante desastres o Disaster Recovery Planning (DRP) —aparentemente— se solapa con la gestión de la continuidad de negocio, si

© Universidad Internacional de La Rioja (UNIR)

bien hay que destacar la diferente perspectiva de cada uno de ellos (negocio vs. tecnológica).

El **Análisis de Impacto de Negocio (BIA)** es un documento que permite conocer cómo un incidente inesperado afectaría en una organización. Para ello, estudia los procesos y las operaciones corporativas, y establece unos tiempos máximos de actuación en los que el impacto de la interrupción es asumible. Los **tiempos** que se definen son:

- **RTO:** tiempo de recuperación objetivo (RTO) es el tiempo en el que se espera que el sistema esté operando de nuevo con normalidad.
- **RPO:** punto de recuperación objetivo (RPO). Marca el estado anterior al desastre en el que vamos a recuperar el sistema. Normalmente, no podremos recuperar nuestro sistema desde el punto en el que sufrió el desastre, sino un punto anterior que nos lo darán las transacciones que están consolidadas, los *backups,* etc.
- **MTD:** Maximum Tolerable Downtime es el tiempo máximo de caída admisible para el sistema.

De este modo, el tiempo real de pérdida en un incidente es la suma de ambos valores RTO+RPO.

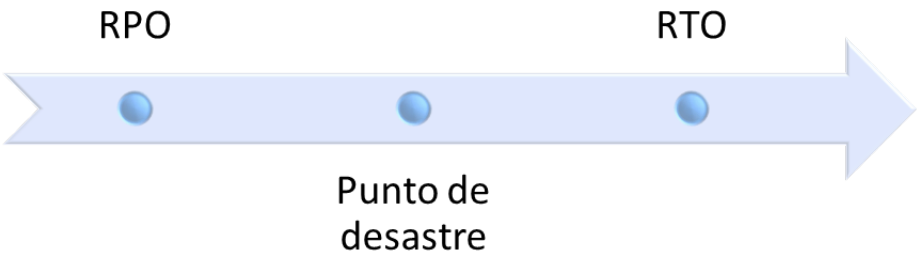


Figura 2. RPO y RTO. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

Procesos clave

Existen varias metodologías de gestión de incidentes, si bien todas ellas identifican una serie de procesos clave en el mecanismo de respuesta:



Figura 3. Procesos clave. Fuente: elaboración propia.

- **Sistemas de detección**: es necesario que existan mecanismos de alerta temprana para poder conocer con la mayor antelación posible la existencia de un ataque y poder responder con prontitud. Para ello, se utilizan sistemas de recolección de eventos y gestión de alertas de seguridad.

- **Procedimientos de respuesta:** se debe elaborar un plan de respuesta en el que queden perfectamente determinadas las acciones a tomar en los diferentes escenarios, así como responsables de ellas.

- **Estrategia de comunicación:** en momentos críticos es importante un buen flujo de comunicación. Se debe establecer un punto central de comunicación para recibir la información y difundirla a terceros.

- **Investigación y análisis:** es muy importante la investigación detallada de los incidentes de seguridad sufridos de modo que se puedan aprender lecciones a futuro y se extraiga el máximo conocimiento del incidente sufrido. En este punto intervienen mecanismos de análisis forense para recoger la mayor cantidad de información posible.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Hay diversas taxonomías de incidentes de seguridad y *frameworks* que desarrollan metodologías para hacerles frente. A continuación, puedes encontrar dos guías como referencias que te permitirán profundizar en el tema:

Guía CCN-STIC 817 Gestión de ciberincidentes: https://www.ccn-cert.cni.es/seriesccn-Stic/800-guia-esquema-nacional-de-seguridad/988-ccn-stic-817-gestion-deciberincident es/file.html.

NIST SP 800-61 r2: Computer Security Incident Handling Guide https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf.

Una aproximación proactiva: CSIRT

Aunque la respuesta ante incidentes es, en sí, una actividad reactiva, existen mecanismos que permiten anticiparse. De ese modo existe una serie de entidades que dan un servicio reactivo al realizar labores de vigilancia, seguimiento, análisis y asistencia ante incidentes.

Estos organismos son los denominados CSIRT (Computer Security Incident Response Team) o CERT (Computer Emergency Response Team). El término CERT es una marca registrada por la Universidad de Carnegie Mellon.

Este servicio de respuesta a incidentes lo prestan a sus «clientes» que son aquellos para los que ha sido concebido y creado. Por ejemplo, existen CSIRT públicos que son creados por las instituciones gubernamentales, y que dan asistencia a las empresas de dicho gobierno, militares, etc. Otros privados, por el contrario, atienden las necesidades de las empresas que los soportan, pero es necesaria una comunicación lo más fluida posible entre todos, a través de la cual se comparta información no crítica sobre seguridad.

© Universidad Internacional de La Rioja (UNIR)

Dichos servicios se pueden dividir en (West-Brown et al 2003):

- **Gestión de incidentes:** es el servicio más importante y la razón de ser de los CSIRT. Se basa en la asistencia a los diferentes «clientes» en el momento en el que estos notifican una incidencia de seguridad. Existe una serie de mecanismos estandarizados para la gestión de dichas incidencias; y los CSIRT —una vez analizadas las notificaciones— establecen la gravedad y prioridad de estas para su atención.

- **Servicios proactivos:** son aquellos en los que los CSIRT trabajan de manera espontánea para tratar de reducir el número de ciberincidentes. Se pueden dividir en:

  - Divulgación sobre seguridad.
  - Vigilancia tecnológica.
  - Auditorías de seguridad.
  - Configuración y mantenimiento de herramientas de seguridad para sus clientes.
  - Servicios de detección de intrusiones.
  - Desarrollos de sus propias herramientas de seguridad.

- **Servicios reactivos:** se activan a demanda de los clientes en el momento en el que estos detectan un problema de seguridad para conseguir una recuperación con el menor impacto posible en tiempo y pérdidas. En este sentido tenemos:

  - Gestión de alertas.
  - Tratamiento de vulnerabilidades.
  - Tratamiento de «artefactos», es un artefacto un elemento que se utiliza para crear una vulnerabilidad.

© Universidad Internacional de La Rioja (UNIR)

- **Servicios de control de calidad:** los CSIRT actúan también como garantes y evaluadores del nivel de seguridad del colectivo al que se dedican. En este sentido, ofrecen además servicios de:

  - Análisis de riesgos.
  - Servicios de continuidad de negocio y recuperación ante desastres (BCM y DRP).
  - Consultoría de seguridad.
  - Campañas de sensibilización.
  - Evaluación y certificación de productos de seguridad.

Nuevos retos de la gestión de incidentes

Los escenarios tecnológicos cada vez son más heterogéneos y complejos, lo que hace más difícil controlar los diferentes aspectos a tener en cuenta en el momento de la gestión de un incidente. Cabe destacar:

- **Computación en la nube**

El proceso de externalización de la infraestructura tecnológica provoca, en último término, una externalización de la gestión de la seguridad, y pierde el control sobre ella.

Recae en el proveedor la responsabilidad de cumplir los estándares de seguridad y, en la empresa, exigir al proveedor protocolos y mecanismos fiables de recuperación ante desastres. Además, la computación en la nube puede suponer nuevos puntos de fallo dentro de la arquitectura tecnológica, ya que se facilita el acceso a terceros y, en el caso de nubes compartidas, posibles problemas de aislamiento.

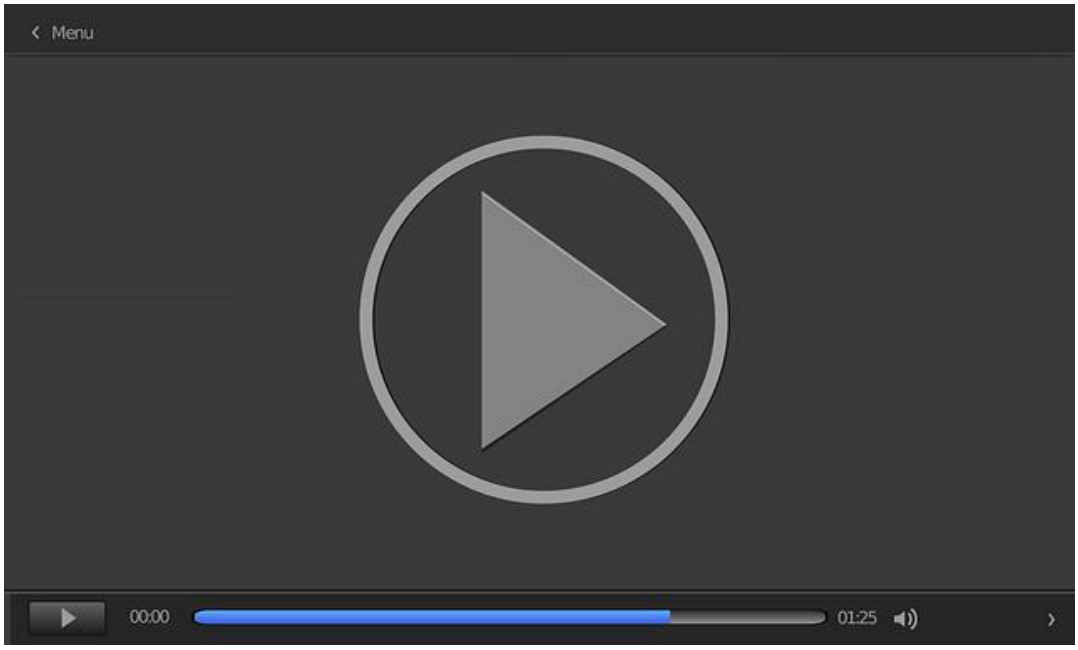
En este sentido es necesario que los protocolos de gestión de incidentes cuenten con:

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

- Gestión de los SLA (Service level agreement) de los proveedores de la nube; de modo que, de manera corporativa, se marquen los requisitos mínimos de seguridad exigibles en la elección de un proveedor *cloud.*
- Verificar el cumplimiento del proveedor de dichos acuerdos, ya sea exigiéndole la información oportuna.
- Implicar al Departamento Legal o de Compliance para determinar posibles restricciones o consecuencias legales a la hora de contratar un proveedor externo.
- Incorporar mecanismos adicionales de seguridad desde dentro de la empresa para fortalecer la infraestructura *cloud* como los CASB (Cloud Access Security Broker) que es un *software* que actúa de elemento central entre la red local y la nube permitiendo definir y monitorizar políticas de seguridad avanzada en el acceso a los servicios de la nube.

En el siguiente vídeo, hablaremos sobre los roles que se cumplen en ciberseguridad:



Accede al vídeo:

https://unir.cloud.panopto.eu/Panopto/Pages/Embed.aspx?id=f3e606b5-126e-

© Universidad Internacional de La Rioja (UNIR)

41ad-8b91-b0c900b5ac16

Movilidad

Los dispositivos móviles presentan, fundamentalmente, dos problemas de seguridad:

- Los **derivados de un acceso remoto:** el poder acceder desde dispositivos externos a la información de nuestra empresa supone siempre un riesgo en el control de dichos accesos.
- Los **derivados del propio terminal:** no solo no se tiene control completo extremo a extremo en la comunicación, sino que, además, tampoco se tiene control sobre el dispositivo. El BYOD (Bring Your Own Device) supone incluso que la propiedad del dispositivo puede que no sea corporativa, y el uso de este a nivel profesional y personal hace que sea más vulnerable a ataques.

Además, cada día los dispositivos son más potentes, y se demanda un mayor uso de estos para más funciones, lo que supone una mayor complejidad tanto en los posibles ataques como en la defensa a establecer. En este sentido, la empresa debe contar —dentro de su política de gestión de incidentes— con mecanismos para el control de dichos dispositivos (MDM, Mobile Device Management).

DRaaS

Dentro de la política de externalización de la infraestructura tecnológica, existe también la externalización de la propia infraestructura de recuperación ante desastres (Desaster Recovery as a Service).

Parece sencillo pensar que una manera de proteger nuestro negocio es crear una infraestructura auxiliar que sirva de respaldo a la principal en momentos de

© Universidad Internacional de La Rioja (UNIR)

emergencia.

El DRaaS se basa, por tanto, en el uso de arquitecturas en la nube que permitirán continuar operando a una organización en un momento de crisis. Para ello, se tienen que definir mecanismos de réplica de datos según los requerimientos especificados en el BIA (RTO, RPO y MDT).

© Universidad Internacional de La Rioja (UNIR)

1.3. Introducción al Análisis Forense Digital

Para comenzar en el mundo del Análisis Forense Digital, el primer paso consiste en saber a qué nos referimos. El Análisis Forense Digital abarca todo lo relacionado con el Análisis Forense de las evidencias digitales como pueden ser equipos informáticos, dispositivos móviles u otros elementos más novedosos como drones o centralitas de vehículos.

El INCIBE (Instituto Nacional de Ciberseguridad) define el Forense Digital como:

«…proceso de investigación de los sistemas de información para detectar toda evidencia que pueda ser presentada como prueba fehaciente en un procedimiento judicial».

De la definición anterior hay que sacar dos ideas clave:

- El Forense Digital es un proceso de investigación.
- Las evidencias que obtengamos deben poder ser presentadas como medio de prueba en un procedimiento judicial.

Otros autores (Brown, 2010) definen el Forense Digital como:

«The art and science of applying computer science knowledge and skills to aid the legal process».

Brown cataloga, a la vez, el Forense Digital **como arte y como ciencia.** Como comenta el autor, aunque el Forense Digital se base en procedimientos ya definidos o en el uso de herramientas que ayuden al investigador, los buenos investigadores forenses tienen la habilidad de ir un paso más allá y llegar a pensar como el autor al

© Universidad Internacional de La Rioja (UNIR)

que se está intentando encontrar.

Objetivos de un análisis forense

El fin último de toda investigación forense es el esclarecimiento de los hechos ocurridos de acuerdo con las evidencias recogidas en la escena del crimen.

Para ello, debemos responder a estas tres preguntas:

- ¿Qué se ha alterado?
- ¿Cómo se ha alterado?
- ¿Quién ha realizado dicha alteración?

Para responder a la primera de las preguntas, hay que ser capaz de detectar los accesos o cambios no autorizados que se han realizado en el sistema. Estos cambios no tienen que consistir únicamente en la alteración física de un fichero, modificándolo o eliminándolo, también hay que ser capaces, por ejemplo, de saber qué ficheros fueron accedidos, aunque solo se trate de la lectura y/o copia de estos.

Un ejemplo de acceso no autorizado, podría ser el acceso a la información del teléfono móvil de una persona, como ha sucedido con el teléfono de algunos famosos, en los que un atacante accede a los datos contenidos, sin alterarlos.

Con la pregunta ¿cómo se ha alterado?, lo que se busca es reconstruir los pasos dados por el autor de los hechos para llegar a comprender cómo hizo lo que hizo, y ser capaces de evitar, en un futuro, que el método utilizado para realizar la alteración se repita.

La última de las preguntas plantea el reto de saber quién fue el autor material de los hechos. Quién ha realizado las modificaciones que han sido detectadas.

© Universidad Internacional de La Rioja (UNIR)

En otros ámbitos de la investigación forense —como pueden ser el análisis dactiloscópico (análisis de las huellas dactilares) o el de ADN— es posible identificar plenamente a la persona autora de los hechos; en el análisis forense digital, no se puede llegar a ser tan precisos.

Cuando se realiza un análisis forense, la conclusión más concreta a la que se va a llegar va a ser el usuario (local o remoto) que realizó las modificaciones y/o la dirección IP o MAC de la máquina desde la cual dichas modificaciones fueron realizadas; por lo que tenemos que ayudarnos de otras técnicas de investigación si se quiere dar con la persona física autora de los hechos.

Etapas de un análisis forense

El NIST (National Institute of Standards and Technology), órgano dependiente el Departamento de Comercio de Estados Unidos, divide en cuatro etapas el proceso de análisis forense: Recolección (Collection), examen (Examination), análisis (Analysis) y redacción del informe pericial (Reporting).

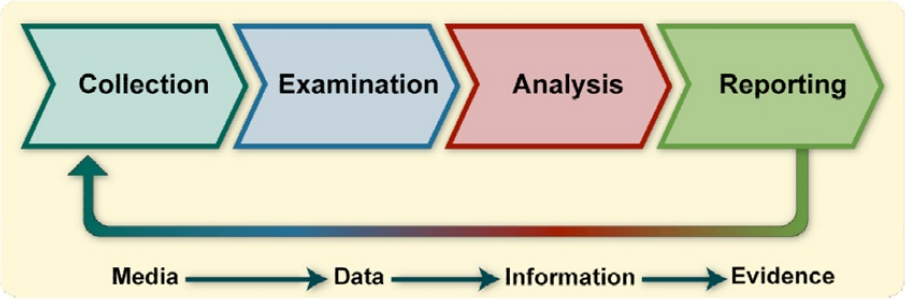


Figura 4. Etapas de un Análisis Forense – NIST: Guide to Integrating Forensic. Techniques into Incident Response.

Durante la etapa de recolección, se deben identificar los elementos en los que es posible encontrar potenciales evidencias digitales y adquirir o recolectar su información. En esta etapa tratamos con los dispositivos electrónicos (Media).

Asemejando el hecho al ámbito forense tradicional, la recolección de las evidencias

© Universidad Internacional de La Rioja (UNIR)

sería algo así como la recogida de una muestra de sangre dentro de la escena de un crimen. La diferencia es que nuestra escena del crimen no es la habitación de un domicilio, sino que es un equipo informático, y la sangre que tenemos que recoger puede ser desde un sencillo archivo de *logs,* hasta el disco duro completo.

La norma internacional ISO/IEC 27037 trata justamente esta etapa del ciclo de vida de un análisis forense digital, aunque la divide en tres: **identificación, adquisición o recolección y preservación.**

La recolección de las evidencias tiene que hacerse con medios que aseguren, en la medida de lo posible, la no modificación de estas tal y como menciona la Ley de Enjuiciamiento Criminal (española) en su artículo 482.3: «Artículo 482.3 de la Ley de Enjuiciamiento Criminal (LECrim). […] el Juez o quien lo represente adoptará las precauciones convenientes para evitar cualquier alteración en la materia de la diligencia pericial».

Al ser necesaria la documentación de cualquier cambio que se haya tenido que realizar y al dejar a disposición judicial una copia de estos por si fuera necesario realizar un nuevo análisis —tal y como indica la Ley de Enjuiciamiento Criminal (española) en su artículo 479—. «Artículo 479 de la LECrim. Si los peritos tuvieren necesidad de destruir o alterar los objetos que analicen, deberá conservarse, a ser posible, parte de ellos a disposición del Juez, para que, en caso necesario, pueda hacerse nuevo análisis».

En la etapa de examen, **se evalúan los datos obtenidos** en la etapa anterior, y se extrae la información relevante de ellos, descartando aquella información que no tiene relación con el análisis que se está realizando.

Durante la siguiente etapa, la de análisis, lo que se busca es la **consecución de los objetivos** de todo análisis forense (responder las preguntas ¿qué?, ¿cómo? y ¿quién?), así como también dar respuesta a cualquier otra pregunta que se nos

© Universidad Internacional de La Rioja (UNIR)

pueda plantear relacionada con el análisis.

Por último, en la etapa de redacción del informe pericial es donde se plasman todos los análisis realizados y los resultados obtenidos, así como las conclusiones alcanzadas en base a dichos resultados.

© Universidad Internacional de La Rioja (UNIR)

1.4. Aspectos legales relacionados

Como se ha mencionado anteriormente, el análisis forense digital está íntimamente relacionado con el ámbito judicial, ya que **busca evidencias** que puedan ser presentadas como medio de prueba en un procedimiento judicial.

Esto implica que hay una serie de **aspectos legales** relacionados con todo el proceso que es necesario conocer.

Cadena de custodia

Para que un elemento pueda servir como elemento probatorio en un procedimiento judicial, se tiene que poder asegurar que no ha sido alterado desde el momento de su recolección hasta su análisis y presentación. Para ello, se utiliza la cadena de custodia.

La cadena de custodia es el proceso mediante el cual la evidencia es transmitida sin modificación alguna, desde quien la ocupa hasta quien la analiza.

Los objetivos que se van a conseguir mediante el uso de la cadena de custodia son:

- Garantizar la integridad de la evidencia.
- Garantizar su autenticidad, permitiendo contrastar su origen.
- Garantizar la posibilidad de localización, permitiendo conocer en todo momento dónde se encuentra una evidencia.
- Garantizar la trazabilidad de los accesos a la evidencia.
- Garantizar su preservación a largo plazo.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

En el ámbito del forense digital, el mantenimiento de la cadena de custodia se lleva a cabo mediante la documentación de las personas custodiantes y los procesos realizados sobre la evidencia y el uso de funciones *hash* que garanticen la integridad.

Así mismo, se ha de llevar un registro de las personas que realicen cualquier operación con la evidencia, indicando la operación realizada, la fecha en que dicha operación ha sido realizada (inicio y finalización) y la persona que la ha realizado.

Delitos de falsedad en la pericia

La figura del perito se corresponde con la de un experto en alguna materia (artística o científica) en la cual el juez no tiene los conocimientos suficientes.

De esto se desprende que un perito puede ser cualquier persona, siempre y cuando sea un experto en la materia sobre la cual pretenda realizar la pericia, no siendo necesaria ningún tipo de titulación al respecto (puede ser necesaria en algunos países), aunque la tenencia de esta respalda el hecho de que el perito es conocedor de la materia sobre la cual tiene titulación. Tampoco es necesario colegiarse para ser considerado perito por un juez en un procedimiento judicial, aunque el colegiarse sirve para tener el respaldo de un colegio de expertos en la materia que aportan credibilidad a la pericia.

La **responsabilidad penal del perito** no solo se da por la realización del hecho con dolo (voluntad deliberada de cometer un delito a sabiendas de su ilicitud), sino también por la imprudencia o falta de celo a la hora de realizar la pericial. Esto último se puede dar, sobre todo, en peritos de parte al no mencionar o no analizar aquellos aspectos que pueden perjudicar a la parte para cual han realizado la pericia.

Por ello, nuestra labor como peritos ha de ser siempre imparcial y destinada a mostrar, de forma clara y entendible para el juez, aquellos aspectos que por su naturaleza técnica no sean fácilmente entendibles. Independientemente de la parte para la que se realice el informe.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

Con el objetivo de evitar la corrupción de los peritos, existe una serie de artículos del código penal dedicados en exclusiva a castigar este tipo de actos. El delito de falso testimonio por perito o con mayor precisión el delito de falsa pericia o falso dictamen del perito se configuran como una modalidad agravada del tipo básico del delito de falso testimonio.

Se trata de un delito que no requiere la producción de un resultado concreto, sino que requiere una realización personal de los elementos del tipo y, además, se trata de un delito especial propio, pues el sujeto activo solo puede serlo el perito, cuyo fundamento radica en la trasgresión del juramento de actuar con objetividad y de decir verdad, tal y como se estipula en los artículos 335.2 y 365 de la Ley de Enjuiciamiento Civil (española), es el bien jurídico protegido, no el interés de las partes, sino el correcto funcionamiento de la administración de justicia, referida a la función jurisdiccional en orden a la correcta valoración de la prueba practicada.

> Artículo 335.2 Objeto y finalidad del dictamen de peritos. Juramento o promesa de actuar con objetividad. Al emitir el dictamen, todo perito deberá manifestar, bajo juramento o promesa de decir verdad, que ha actuado y, en su caso, actuará con la mayor objetividad posible, tomando en consideración tanto lo que pueda favorecer como lo que sea susceptible de causar perjuicio a cualquiera de las partes, y que conoce las sanciones penales en las que podría incurrir si incumpliere su deber como perito.

«Artículo 365.1 Juramento o promesa de los testigos. Antes de declarar, cada testigo prestará juramento o promesa de decir verdad, con la conminación de las penas establecidas para el delito de falso testimonio en causa civil, de las que le instruirá el tribunal si manifestare ignorarlas».

Se distingue entre **falso testimonio propio** (faltar a la verdad maliciosamente en su dictamen) y el **falso testimonio impropio** (sin faltar sustancialmente a la verdad, la alterasen con reticencias, inexactitudes o silenciando hechos o datos relevantes que le fueren conocidos). La conducta típica consiste no en un error en el dictamen, sino en faltar a la verdad en lo que el perito sabe y entiende, con infracción del deber de

© Universidad Internacional de La Rioja (UNIR)

actuar con objetividad, antes identificado con el deber de proceder bien y fielmente en el desempeño del cargo, exigiéndose que el perito «actúe con conocimiento de la inexactitud del dictamen presentado, faltando así al deber de veracidad impuesto a todo perito que sirve a la Administración de Justicia».

El **tipo objetivo** requiere que la declaración del perito sea falsa. Puede consistir tanto en una acción (aportar juicios inveraces, bien sea por falta de suficiente motivación o que esta sea arbitraria, o bien que hayan sido tergiversadas las bases fácticas del informe) como en una omisión (silenciar juicios relevantes induciendo al juez una representación alterada de los extremos objeto del dictamen). Y el tipo subjetivo requiere dolo directo de estar dictaminando falsamente, esto es, y en la dicción legal «maliciosamente», referido, no a la necesidad de un especial elemento subjetivo del injusto, sino al conocimiento de la falsedad propio del dolo.

Una de las mayores dificultades para la sanción penal es la comprobación de la falsedad, que requiere su confirmación por otro perito de la misma especialidad, de modo que, salvo que aquella sea muy evidente, lo más que encontraremos serán opiniones científicas, técnicas o artísticas discrepantes.

La doctrina jurisprudencial ha destacado la mayor complejidad en la determinación de la comisión de un delito de falso testimonio en el caso de los peritos que en el de los testigos, ya que estos declaran sobre hechos, mientras que para aquellos la conducta penal comenzará a partir de la línea que separa lo científicamente opinable de lo que es insostenible bajo cualquier óptica, razón por la cual el art. 459 Código Penal (español) exige que los peritos falten a la verdad, pero maliciosamente.

«Código Penal. Artículo 458.1: El testigo que faltare a la verdad en su testimonio en causa judicial, será castigado con las penas de prisión de seis meses a dos años y multa de tres a seis meses».

«Código Penal. Artículo 459: Las penas de los artículos precedentes se impondrán en su mitad superior a los peritos o intérpretes que faltaren a la verdad

© Universidad Internacional de La Rioja (UNIR)

maliciosamente en su dictamen o traducción, los cuales serán, además, castigados con la pena de inhabilitación especial para profesión u oficio, empleo o cargo público, por tiempo de seis a doce años».

«Código Penal. Artículo 460: Cuando el testigo, perito o intérprete, sin faltar sustancialmente a la verdad, la alterare con reticencias, inexactitudes o silenciando hechos o datos relevantes que le fueran conocidos, será castigado con la pena de multa de seis a doce meses y, en su caso, de suspensión de empleo o cargo público, profesión u oficio, de seis meses a tres años».

De menor incidencia práctica son los **delitos de cohecho.** El cohecho, cuya conducta típica consiste en la solicitud, recepción o aceptación de dádiva, presente, ofrecimiento o promesa, protege la confianza depositada en los funcionarios públicos, otorgándose, a tal efecto y a los peritos, la condición de funcionario público.

«Código Penal. Artículo 420: La autoridad o funcionario público que, en provecho propio o de un tercero, recibiere o solicitare, por sí o por persona interpuesta, dádiva, favor o retribución de cualquier clase o aceptare ofrecimiento o promesa para realizar un acto propio de su cargo, incurrirá en la pena de prisión de dos a cuatro años, multa de doce a veinticuatro meses e inhabilitación especial para empleo o cargo público y para el ejercicio del derecho de sufragio pasivo por tiempo de cinco a nueve años».

«Código Penal. Artículo 422: La autoridad o funcionario público que, en provecho propio o de un tercero, admitiera, por sí o por persona interpuesta, dádiva o regalo que le fueren ofrecidos en consideración a su cargo o función, incurrirá en la pena de prisión de seis meses a un año y suspensión de empleo y cargo público de uno a tres años».

Con respecto a la responsabilidad civil del perito, en ausencia de una regulación legal específica se ha objetado que la exigencia de responsabilidad civil podría

© Universidad Internacional de La Rioja (UNIR)

afectar a la autoridad de la cosa juzgada. Pero parece más acertado distinguir entre la reparación de los perjuicios originados por un dictamen inexacto y la invariabilidad de la sentencia que en dicho juicio se ha dictado. En efecto, al igual que sucede en el proceso de responsabilidad civil de jueces y magistrados, en el que la sentencia que le pone fin no alterará la resolución firme recaída en el proceso, tampoco la sentencia declarando la responsabilidad civil del perito permitirá alterar o modificar la sentencia de la que se origina dicha responsabilidad, pues a salvo del cauce de la revisión de las sentencias firmes, la responsabilidad civil del perito por dictamen inexacto no destruye la fuerza de la cosa juzgada.

Además, el que un perito cometa algún tipo de delito de falsedad en su pericia también puede suponerle responsabilidad disciplinaria ante los órganos judiciales, exigible por el juez o tribunal ante el que se haya emitido el dictamen, y una responsabilidad disciplinaria del perito ante su Colegio profesional, exigible normalmente previa reclamación del particular agraviado o de oficio por la propia Corporación o Institución.

Esta responsabilidad disciplinaria puede concurrir junto con la penal o civil, a modo de sanción complementaria, o puede ser autónoma, cuando la conducta del perito, sin constituir un ilícito penal o civil, infringe las normas de conducta o ética profesional ante los tribunales.

© Universidad Internacional de La Rioja (UNIR)

1.5. Referencias bibliográficas

J. Roberts, S. (10 de enero de 2016). Introduction to DFIR. https://sroberts.medium.com/introduction-to-dfir-d35d5de4c180.

NIST. (2020). Security and Privacy Controls for Federal Information Systems and Organizations. https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf.

NIST. (2006). Guide to Integrating Forensic Techniques into Incident Response. https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-86.pdf.

M. J. West-Brown, D. Stikvoort, K.-P. Kossakowski, G. Killcrece, R. Rue-fle, M. Zajicek. (2003). Handbook for Computer Security Incident Response Teams (CSIRTs). Carneige Mellon Software Engineering Institute.

ENISA. (2018). Reference Incident Classification Taxonomy. https://www.enisa.europa.eu/publications/reference-incident-classification-taxonomy.

INTERPOL. (2018). Global Guidelines for Digital Forensics Laboratories. https://www.interpol.int/es/content/download/13501/file/INTERPOL_DFL_GlobalGuidelinesDigitalForensicsLaboratory.pdf.

Brown, C. L. T. (2010). *Computer evidence. Collection and preservation.* Boston: Course Technology PTR.

EC-Council. (2016). *Computer Forensics: Investigation Procedures and Response.* Cengage Learning.

© Universidad Internacional de La Rioja (UNIR)

Who is Who During a Cyber Incident Response Investigation

Winterfeld, S. (2017). *Who is Who During a Cyber Incident Response Investigation* [Vídeo]. YouTube. https://www.youtube.com/watch?v=cZhvQsvNIGM

Steve Winterfeld, Director de Ciberseguridad en Nordstrom, nos habla sobre los distintos roles implicados en la respuesta e investigación de un ciberincidente.

© Universidad Internacional de La Rioja (UNIR)

Respuesta a Incidentes: Políticas de seguridad para la PYME

INCIBE. (s. f.). *Respuesta a Incidentes: Políticas de seguridad para la PYME*. https://www.incibe.es/sites/default/files/contenidos/politicas/documentos/respuesta-incidentes.pdf

Breve documento resumen sobre la mejora continua en la respuesta a incidentes de seguridad.

© Universidad Internacional de La Rioja (UNIR)

Digital Forensics, Davin Teo

TEDx. (2015, 9 diciembre). *Digital Forensics | Davin Teo | TEDxHongKongSalon* [Vídeo]. YouTube. https://www.youtube.com/watch?v=Pf-JnQfAEew

Davin Teo, Director de Alvarez & Marsal, una prestigiosa firma asiática de Forense Digital nos cuenta su visión sobre el análisis forense.

© Universidad Internacional de La Rioja (UNIR)

Test

1. ¿Qué es un incidente?

A. Un evento planificado con alta probabilidad de comprometer las operaciones de la entidad.

B. Un evento no deseado con alta probabilidad de comprometer las operaciones de la entidad.

C. Un evento planificado con baja probabilidad de comprometer las operaciones de la entidad.

D. Un evento no deseado con baja probabilidad de comprometer las operaciones de la entidad.

2. Los incidentes pueden ser de diversa naturaleza. Algunos de los más comunes son:

A. Desastres naturales.

B. Ataques externos y/o externos.

C. Errores humanos.

D. Todas las anteriores son correctas.

3. ¿Qué significan las siglas RTO?

A. Punto de recuperación objetivo.

B. Tiempo de recuperación al origen.

C. Punto de recuperación al origen.

D. Tiempo de recuperación objetivo.

4. ¿Cuál de los siguientes no es un proceso clave en la gestión de incidentes?

A. Los sistemas de detección.

B. Los procedimientos de acción.

C. La estrategia de comunicación.

D. La investigación y el análisis.

© Universidad Internacional de La Rioja (UNIR)

5. ¿Cuál de estos no es un objetivo de un análisis forense?

A. Averiguar qué se ha alterado.

B. Descubrir por qué se ha realizado la alteración.

C. Saber cómo se ha realizado la alteración.

D. Descubrir quién ha realizado la alteración.

6. Cuando intentamos responder a la pregunta: ¿quién ha realizado la alteración?

A. Tenemos que descubrir a la persona física responsable de la alteración.

B. Podemos llegar a descubrir el usuario del sistema que realizó la modificación.

C. Podemos obtener la dirección IP o MAC del equipo desde el que se realizó la alteración.

D. Las respuestas B y C son correctas.

7. Con respecto a la recolección de evidencias digitales:

A. Tiene que hacerse con medios que aseguren, en la medida de lo posible, la no modificación de estas.

B. Es necesario documentar los cambios que se hayan tenido que realizar en el equipo si no ha sido posible evitar su modificación.

C. Es uno de los primeros pasos que se dan a la hora de realizar un análisis forense digital.

D. Todas las anteriores son correctas.

8. Las etapas de un análisis forense según el NIST son:

A. Recolección, examen, análisis y redacción del informe pericial.

B. Recolección, respuesta, examen y análisis.

C. Recolección, examen y análisis.

D. Recolección, análisis y redacción del informe pericial.

© Universidad Internacional de La Rioja (UNIR)

9. Durante la fase de recolección, lo que se busca es:

A. Garantizar que lo que se analiza es lo que se ha recolectado.

B. Obtener las evidencias que son consideradas de interés.

C. Dar respuesta a la pregunta ¿cómo se ha alterado?

D. Ninguna es correcta.

10. En el ámbito del análisis forense digital, el mantenimiento de la cadena de custodia se suele llevar a cabo mediante:

A. La documentación de las personas custodiantes de la evidencia.

B. El uso de funciones *hash* que garanticen la integridad la evidencia.

C. Un registro de las personas que realicen cualquier operación con la evidencia

D Todas las anteriores son correctas.

© Universidad Internacional de La Rioja (UNIR)